

DEVELOPMENT OF SECURE APPLICATIONS (DSA)

Dezvoltarea aplicațiilor securizate (DAS)

PBL PROJECT DEVELOPMENT | INTERNSHIP GUIDELINES

Project Description

This semester's PBL project centers on creating a secure application. Students will integrate security practices throughout the development lifecycle, ensuring the application is resilient against cyber threats.

During the one-month internship in September, students will work in teams with company mentors to define and begin developing a realistic Minimum Viable Product (MVP). The purpose of September is to establish the project foundation. DAS will continue from October to December at university

Project Objectives

1. Security Integration: Embed security measures at every development stage.
2. Mitigate Vulnerabilities: Address common vulnerabilities in frontend, backend, and database management.
3. Compliance: Adhere to industry security standards and regulations.
4. Incident Response: Develop skills in detecting and responding to security incidents.

Technical Requirements

1. Encryption and Authentication

- Implement strong encryption algorithms for data at rest and in transit.
- Use multi-factor authentication (MFA) to enhance user security.
- Ensure secure password storage using hashing algorithms.

2. Secure APIs

- Validate all inputs to prevent injection attacks.
- Use OAuth 2.0 for secure API authentication and authorization.
- Ensure proper error handling to avoid exposing sensitive information.

3. Frontend Security

- Mitigate Cross-Site Scripting (XSS) by escaping all user inputs and using Content Security Policy (CSP).

- Prevent Cross-Site Request Forgery (CSRF) using anti-CSRF tokens.
- Implement secure cookie attributes (HttpOnly, Secure, SameSite).

4. Backend Security

- Prevent SQL Injection by using parameterized queries and ORM frameworks.
- Secure session management and ensure proper timeout and invalidation mechanisms.
- Regularly update and patch server software to close known vulnerabilities.

5. Database Management

- Use encryption for sensitive data storage.
- Implement role-based access control (RBAC) to limit data access.
- Ensure secure backup and recovery processes.

Expected Outcomes

1. Secure Application: A secure application, may not be fully functional, though students should be able to thoroughly describe the security aspects they considered in their projects and display a clear understanding of security vulnerabilities in software development.
2. Security Documentation: Comprehensive documentation of security measures, threat models, and risk assessments.
3. Incident Response Plan: A detailed plan for responding to security incidents.
4. Final Presentation: Demonstration and discussion of the application's security features and development challenges.

Actions for Students

1. Security Requirement Analysis: Identify and document the security requirements specific to the application; analyze potential threats and vulnerabilities during the planning phase.
2. Design: Develop a design plan that integrates security principles, focusing on secure architecture, data protection, and access control; design threat mitigation strategies, including encryption, authentication, and authorization mechanisms.
3. Implementation of Security Measures: Write code that incorporates security practices, such as input validation, secure coding techniques, and proper error handling; implement encryption for sensitive data both at rest and in transit.

4. Documentation: Maintain thorough documentation covering all security measures, threat models, and risk assessments; document security decisions and the processes used to secure the application.
5. Final Presentation: Prepare and deliver a presentation focusing on the security aspects of the application, the challenges encountered, and the demonstration of the security features implemented.

Work During the September Internship

During September, students should work together with their company mentors on the following activities:

1. MVP Idea: Choose a realistic project idea that can be extended after the internship.
2. Domain and Security Analysis: Analyze the application domain and identify the main security risks relevant to the project.
3. Architecture and Technologies: Choose appropriate technologies, define the application architecture, and organize the project structure.
4. Security Priorities: Decide which security measures are necessary for the first MVP and which can be implemented later.
5. Core Implementation: Begin implementing the essential functionality of the application.
6. Basic Security Controls: Implement several important security measures appropriate for the selected project.

Possible Security Measures

Depending on the project, security measures may include:

1. Authentication and Access Control

- Secure authentication and authorization.
- Two-Factor Authentication (2FA).
- Secure password hashing and password policies.
- Role-based access control (RBAC).
- Brute-force protection.

2. API and Session Security

- API rate limiting and API access control.
- Secure JWT or session management.

- Secure error handling.

3. Input and Application Security

- Input validation and sanitization.
- Protection against SQL Injection, XSS, CSRF, IDOR, and privilege escalation.
- CAPTCHA protection against bots.
- Secure file upload and download mechanisms.

4. Data and Monitoring

- Encryption of sensitive information.
- Security logging and monitoring.

Students are not expected to implement all security mechanisms during September. The team and mentor should select the protections that are most important for the first version of the MVP and plan the remaining improvements for October to December.

Security Measure Explanation

For each security measure selected for the project, students should be able to explain:

1. Security Problem: What security problem or attack the measure addresses.
2. Relevance: Why the problem could be relevant to their application.
3. Implementation: How the security measure was implemented.
4. Testing: How they tested whether the protection works.
5. Limitations: What limitations remain and what could be improved later.

Role of Company Mentors

Company mentors should guide the teams during September by helping them understand realistic risks for the selected project, recommending suitable approaches or technologies, and giving practical examples of how similar security concerns are handled in real software projects.

Expected Outcomes by the End of September

1. Project Definition: A clearly defined project idea and scope.
2. Initial MVP: A first working version containing the essential functionality.
3. Security Analysis: A basic analysis of the main risks and security requirements.
4. Basic Security Measures: Several prioritized security controls implemented and tested.

5. Development Plan: A clear plan for the work and security improvements to be completed from October to December.